

Active Directory Basics

TryHackMe Lab Walkthrough

Windows Active Directory Fundamentals | Hands-on Administrative Lab Documentation

PREPARED BY	Anurag Ravankar
ROLE	Cybersecurity Student Security Enthusiast
PLATFORM	TryHackMe
LAB TYPE	Blue Team / Windows Active Directory Fundamentals
VERSION	1.0
DATE	September 16, 2026

Prepared for professional portfolio review and internship / job applications

Table of Contents

Table of Contents	2
1. Executive Summary	4
2. Lab Objectives	5
3. Lab Environment	5
Platform and Access	5
Windows Components Exercised	6
4. Introduction to Active Directory.....	6
Windows Domain	6
Identity and Access Management (IAM)	6
Authentication and Authorization.....	6
LDAP	7
DNS in Active Directory	7
Why Enterprises Use Active Directory.....	7
5. Core Components of Active Directory	8
Domain Controller	8
Users	8
Groups.....	8
Machine Accounts.....	9
Organizational Units.....	9
6. Task 2 — Windows Domains	9
7. Task 3 — Exploring Active Directory Objects.....	10
8. Task 4 — Managing Users in Active Directory	12
9. Delegation in Active Directory.....	16
Least Privilege	16
Administrative Boundaries	16
Common Enterprise Use Cases.....	16
Best Practices	16
10. Task 5 — Managing Computers.....	16
Computer Object Categories	17
Why Separate OUs Are Recommended.....	18
11. Organizational Unit Design Best Practices.....	18

12. Task 6 — Group Policy Objects (GPO)	18
How GPO Works	18
Computer Policies vs. User Policies	19
Local vs. Domain GPO	19
Inheritance and Precedence	19
Enforcement and Blocking	19
Loopback Processing	19
SYSVOL and Refresh Behavior	19
13. SYSVOL Explained	20
Purpose	20
Replication	20
Storage Path and Access Permissions	21
What Lives in SYSVOL	21
14. Task 7 — Authentication in Active Directory	21
Key Terms	21
Kerberos vs. NetNTLM	21
15. Kerberos Authentication Flow	22
Step-by-Step Sequence	22
16. NetNTLM Authentication Flow	23
Challenge-Response Mechanism	23
Hash Usage and Legacy Compatibility	23
Security Risks	23
17. Task 8 — Trees, Forests, and Trust Relationships	24
Domain, Tree, and Forest	24
Trust Relationship Types	24
Enterprise Example	25
18. Security Best Practices Learned	25
19. Common Active Directory Attack Surface	26
20. Troubleshooting Notes	27
21. Key Learnings	27
22. Conclusion	28
23. References	28

1. Executive Summary

Active Directory (AD) is Microsoft's directory service for Windows domain networks. It provides centralized authentication, authorization, and management of users, computers, and other network resources, and it underpins identity and access management in the large majority of enterprise Windows environments. Understanding how it is built and administered is foundational for anyone working in blue team operations, IT administration, or penetration testing.

Organizations adopt Active Directory because it replaces per-machine local accounts with a single, centrally managed identity store. One set of domain credentials lets a user authenticate to any joined workstation, application, or file share, while administrators apply consistent security policy, delegate administrative rights in a controlled way, and audit activity from a single console. This centralization is what makes AD indispensable at scale, and it is also why compromising it is frequently the most damaging event in an enterprise breach.

This report documents my completion of the “Active Directory Basics” room on TryHackMe, a hands-on lab covering the core building blocks of a Windows domain: domain controllers, users, groups, machine accounts, organizational units, Group Policy, Kerberos and NetNTLM authentication, and the trust relationships that connect domains into trees and forests.

The goal of documenting the lab in this format is to demonstrate that the underlying concepts are understood well enough to explain, defend, and troubleshoot in a real environment — not simply that the room's tasks were marked complete. Every flag, password, and credential produced during the exercise has been redacted throughout; the value of this report lies in the explanation of the mechanics, not in the answers to the room.

Skills Practiced

- Navigating and administering Active Directory through the ADUC console
- Creating and organizing Organizational Units to reflect a department and location hierarchy
- Resetting and managing user account credentials via GUI and PowerShell
- Interpreting Group Policy Object (GPO) scope, inheritance, and precedence
- Explaining Kerberos and NetNTLM authentication flows at a protocol level

Expected Learning Outcome

By the end of this lab, the objective was to be able to describe how a Windows domain authenticates and authorizes users end-to-end, to perform routine AD administrative tasks confidently, and to connect each administrative action back to the security posture it creates or protects — the same lens a SOC analyst or penetration tester uses when assessing a domain.

NOTE

This report is written as administrative lab documentation, not a step-by-step CTF walkthrough. All flags, passwords, and credentials produced by the room have been replaced with [REDACTED] throughout.

2. Lab Objectives

The table below summarizes the core objectives of the Active Directory Basics room, mapped to the concepts each one is designed to build.

Objective	Description
Windows Domains	Understand what a domain is and how it centralizes identity across a network.
Domain Controller	Identify the role of the DC as the authentication and policy authority for the domain.
Users and Groups	Create, locate, and manage user accounts and the security groups that grant them access.
Organizational Units	Use OUs to structure objects for delegation and targeted policy application.
Delegation	Grant scoped administrative rights without full Domain Admin membership.
Group Policy (GPO)	Apply consistent computer and user configuration across the domain.
Kerberos	Explain the ticket-based authentication protocol used by modern Windows domains.
NetNTLM	Explain the legacy challenge-response protocol retained for backward compatibility.
Trees and Forests	Understand how multiple domains combine into larger trust structures.

3. Lab Environment

Platform and Access

Item	Details
Platform	TryHackMe
Room Name	Active Directory Basics
Operating System	Windows Server (Domain Controller) with a domain-joined Windows client
Access Method	In-browser RDP via the TryHackMe AttackBox / split-screen VM
Tools Used	Active Directory Users and Computers (ADUC), PowerShell, Group Policy Management Console (GPMC), Windows Explorer

Windows Components Exercised

Component	Role in This Lab
PowerShell	Scripted administrative actions such as password resets, run from an elevated console.
ADUC	Primary GUI for creating and managing users, groups, computers, and Organizational Units.
Group Policy	Distributed computer and user configuration via GPOs linked to OUs.
SYSVOL	Shared folder used to replicate GPO templates and scripts to every domain controller.
DNS	Name resolution that lets domain members locate the domain controller and its services.
Authentication Protocols	Kerberos (default) and NetNTLM (legacy fallback) for logon and resource access.

4. Introduction to Active Directory

Active Directory is a directory service developed by Microsoft that runs on Windows Server. At its core, a directory service is a structured, hierarchical store of information about the objects on a network — users, computers, groups, printers, and more — along with the services that let administrators query and manage that information consistently. AD organizes these objects inside domains, and every object is tracked with a Distinguished Name (DN) that reflects its position in the directory tree.

Windows Domain

A Windows domain is a logical grouping of computers and users that share a central directory database, hosted on one or more Domain Controllers. Joining a computer to a domain replaces its reliance on local accounts with domain accounts: any user with valid domain credentials can log on to any domain-joined machine, subject to whatever permissions and policies apply to them. This is the fundamental shift AD makes possible — identity becomes a property of the domain, not of any single machine.

Identity and Access Management (IAM)

Active Directory is, in practice, an enterprise IAM system. It answers two separate questions for every access attempt: who is this (authentication), and what are they allowed to do (authorization). Keeping these concerns centralized means a single account disable, password reset, or group membership change takes effect everywhere at once, instead of requiring administrators to touch dozens of individual machines.

Authentication and Authorization

Authentication is the process of proving identity — typically a username and password, validated against the domain's Kerberos Key Distribution Center. Authorization happens afterward: once identity is established, the domain controller and the resource being accessed evaluate the user's group memberships

and any explicit permissions to decide what they can actually do. A user can authenticate successfully and still be authorized for almost nothing, which is the basis of least-privilege design.

LDAP

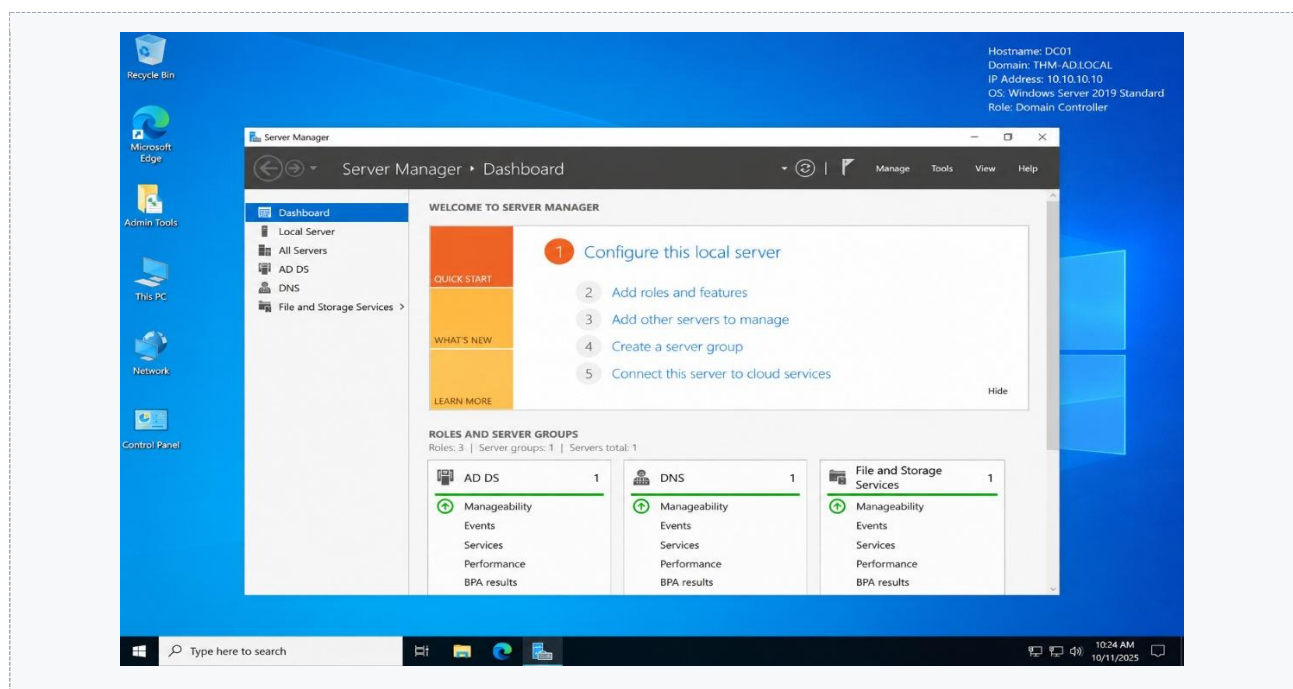
The Lightweight Directory Access Protocol (LDAP) is the protocol clients and applications use to query and modify objects stored in Active Directory. Every AD object can be addressed by an LDAP Distinguished Name built from its Common Name (CN) or Organizational Unit (OU) components and the Domain Component (DC) values of the domain — for example, a user named Jane Smith in a Sales OU might be addressed as CN=Jane Smith,OU=Sales,DC=corp,DC=local. LDAP is also the protocol most AD enumeration tools rely on, which is why exposed or misconfigured LDAP access is a frequent finding in security assessments.

DNS in Active Directory

Active Directory depends on DNS to function at all — not as an optional convenience, but as a hard requirement. Domain-joined computers use DNS SRV records to locate domain controllers, the Kerberos KDC, and the Global Catalog. AD-integrated DNS zones store this information directly inside the directory itself and replicate it to every domain controller, which is why a DNS outage on a Windows domain is functionally equivalent to an authentication outage.

Why Enterprises Use Active Directory

- Single sign-on across every domain-joined resource with one set of credentials
- Centralized policy enforcement through Group Policy, rather than per-machine configuration
- Delegated administration, so help-desk staff can be granted narrow rights without full admin access
- Centralized auditing of authentication and object changes for compliance and incident response
- A single source of truth for identity that other enterprise systems (email, VPN, file shares) can trust



5. Core Components of Active Directory

This section breaks down the building blocks that make up a Windows domain, and the responsibility each one carries.

Domain Controller

The Domain Controller (DC) is a server running the Active Directory Domain Services role. It is the authority for the domain and carries several responsibilities simultaneously:

- Authentication — validates logon credentials as the Kerberos Key Distribution Center (KDC)
- DNS — typically hosts the AD-integrated DNS zone the domain depends on
- Replication — synchronizes directory changes with every other DC in the domain via multi-master replication
- SYSVOL — hosts the shared folder that distributes Group Policy templates and logon scripts
- Kerberos ticketing — issues the Ticket Granting Tickets (TGTs) and service tickets that authorize access
- FSMO roles — five Flexible Single Master Operations roles (Schema Master, Domain Naming Master, RID Master, PDC Emulator, Infrastructure Master) handle operations that cannot be multi-mastered safely

Users

A user object represents a person (or a service) that can authenticate to the domain. Each user account carries a Security Identifier (SID) — a unique value that Windows uses internally to represent the account in access tokens and on Access Control Lists, rather than the human-readable username. Key attributes include the logon name (sAMAccountName / userPrincipalName), group memberships, the account's enabled/disabled state, password policy flags, and the OU it lives in, which determines what Group Policy applies to it.

Groups

Groups exist to grant permissions to many accounts at once rather than assigning rights to individual users. AD distinguishes between two group types and three scopes:

Group Type	Purpose	Example
Security Group	Used to assign permissions and rights to resources.	Domain Admins, a department file-share group
Distribution Group	Used only for email distribution lists; carries no security permissions.	all-staff@corp.local mailing list

Built-in groups deserve particular attention because of the power they carry. Domain Admins has full administrative control over the entire domain; Enterprise Admins has that same control across every domain in the forest. Best practice is to keep membership in both groups as small as possible, avoid using

them for day-to-day administrative work, and rely on delegated, task-scoped permissions instead (see Section 9).

Machine Accounts

Every computer joined to the domain receives its own machine account, created automatically during the join process. Machine accounts follow a strict naming convention: the computer's hostname followed by a dollar sign, for example a workstation named TOM-PC would receive the account TOM-PC\$. This is not cosmetic — the trailing \$ marks the object as a computer account to Windows tooling and keeps its namespace separate from user accounts. A machine account authenticates the computer itself to the domain (independently of whichever user is logged on), which is what allows Group Policy and machine-level trust to function before any user ever logs on.

Organizational Units

Organizational Units (OUs) are containers used to organize users, groups, and computers into a structure that mirrors the business — typically by department, location, or function. Two things make OUs important beyond simple organization: they are the unit Group Policy links to, and they are the unit administrative rights can be delegated over. Both Group Policy and delegated permissions apply to an OU and, by default, are inherited by every nested OU beneath it, which makes OU design a security decision as much as an organizational one. Nesting OUs too deeply or too shallowly both create administrative pain later, which Section 11 covers in more detail.

6. Task 2 — Windows Domains

Concept

This task establishes the domain as the unit of trust and administration for everything that follows in the room. Rather than treating “Active Directory” as an abstract term, the task grounds it in the specific domain controller and domain-joined client provided in the lab environment.

Explanation

A domain gives every machine that joins it a shared source of identity and policy. Before a computer joins a domain, its accounts, passwords, and local policies exist only on that one machine. After joining, the machine trusts the domain controller to authenticate users and to push down Group Policy, and it gives up a certain amount of local autonomy in exchange for centralized manageability. This is the trade-off every enterprise makes at scale: local flexibility for domain-wide consistency and control.

What I Observed

Working inside the provided environment, the domain-joined client trusted the domain controller implicitly for logon: any domain account with appropriate rights could authenticate at the client without any account needing to exist locally on that machine. Domain membership was visible in the System Properties of the client, and DNS resolution for the domain's internal name only worked because the client was pointed at the domain controller for DNS — confirming how tightly AD and DNS are coupled in practice, not just in theory.

Administrator Perspective

From an administrator's seat, a Windows domain converts “who can log in where” from a per-machine problem into a per-domain policy. Onboarding, offboarding, and access reviews all become operations performed once, centrally, rather than repeated across every workstation an employee happens to use.

Learning Outcome

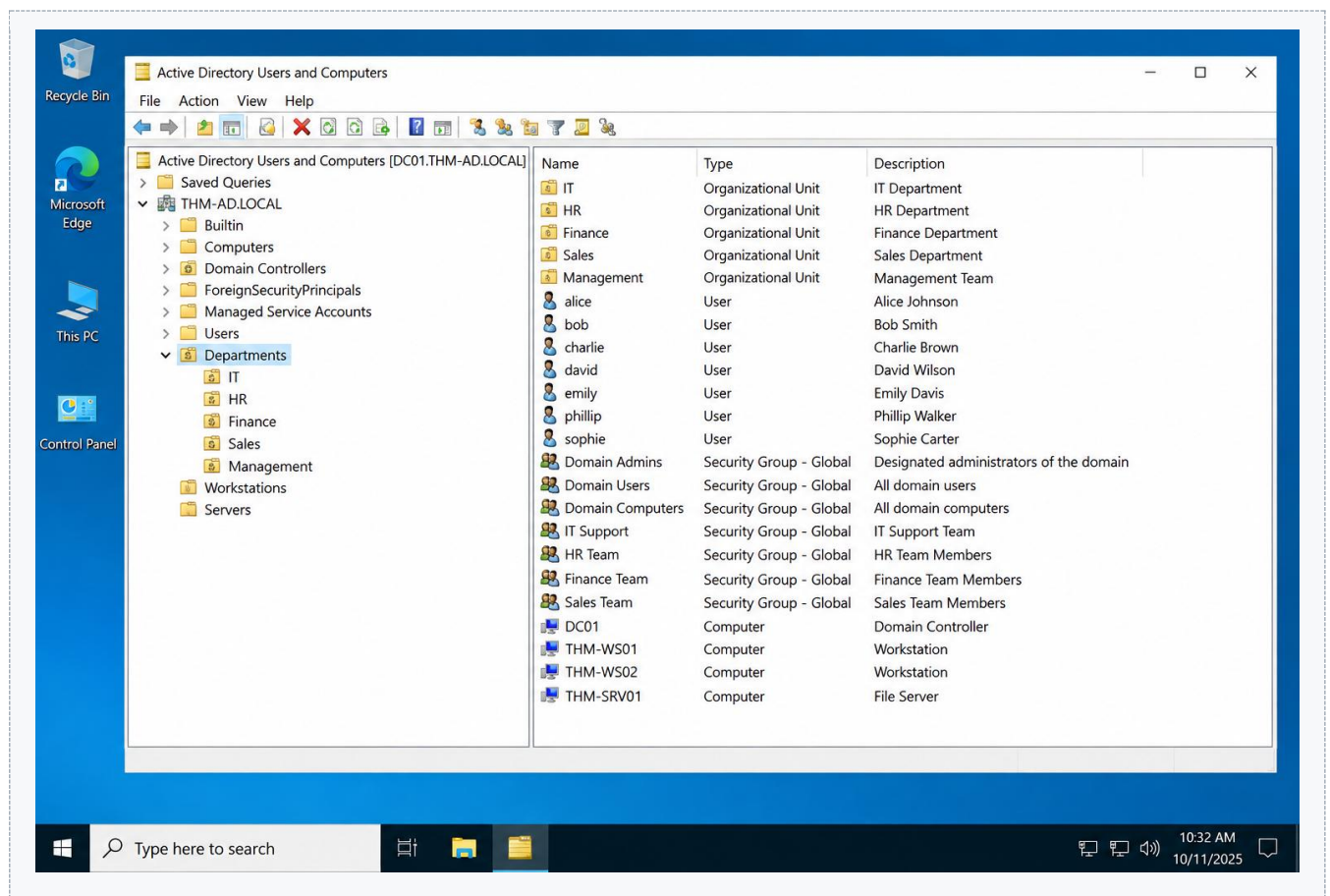
This task reinforced that a domain is fundamentally a trust relationship: client machines delegate authentication and policy authority to the domain controller, and that delegation is what every later task in this lab — users, groups, OUs, GPOs — builds on top of.

7. Task 3 — Exploring Active Directory Objects

This task is a guided tour of the Active Directory Users and Computers (ADUC) console — the primary GUI tool administrators use for day-to-day directory management. The goal was to become comfortable locating and reading every major object type before making any changes to them in later tasks.

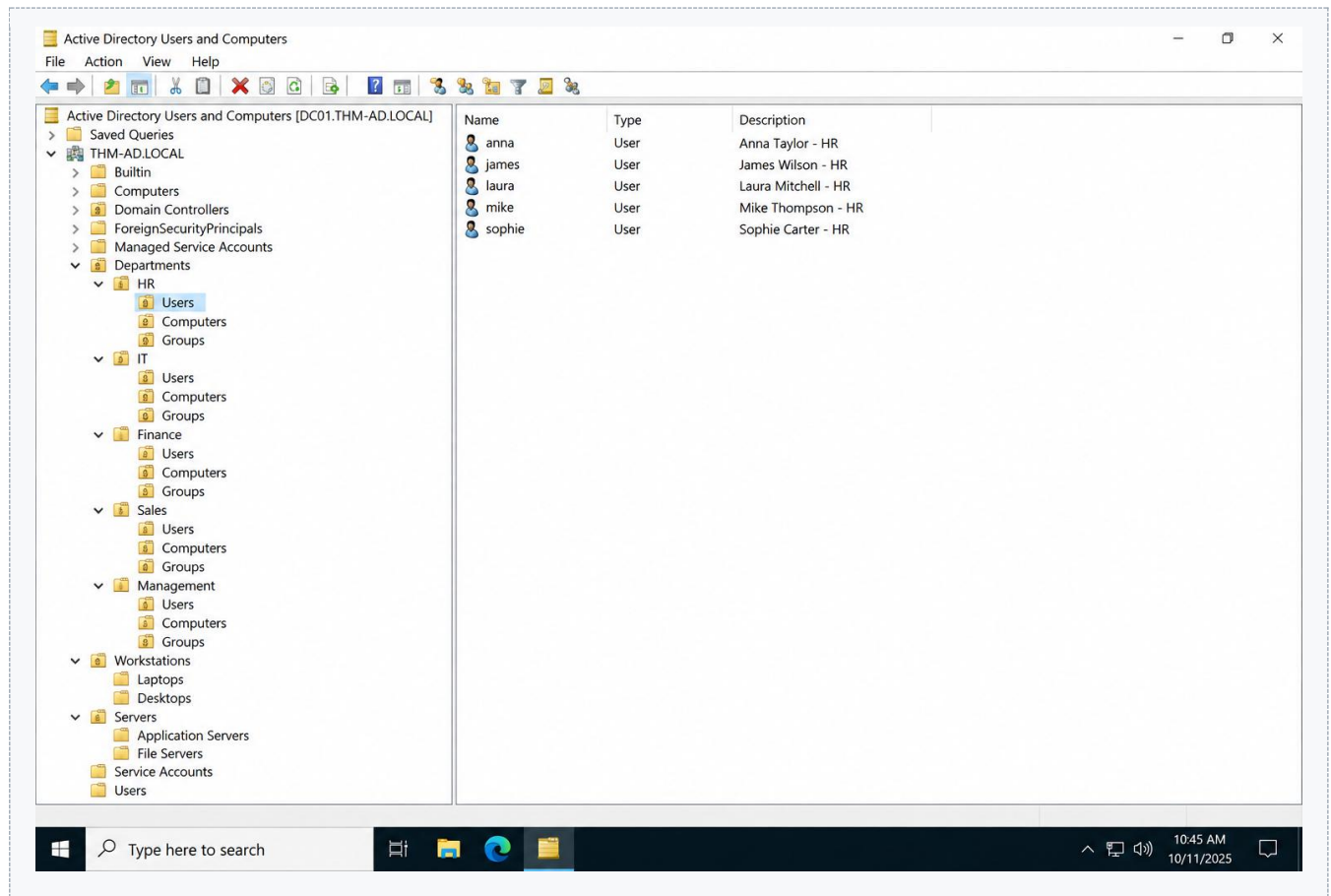
Opening Active Directory Users and Computers

ADUC was opened from the domain controller via Server Manager → Tools → Active Directory Users and Computers, which is equivalent to running `dsa.msc` directly from a Run prompt.



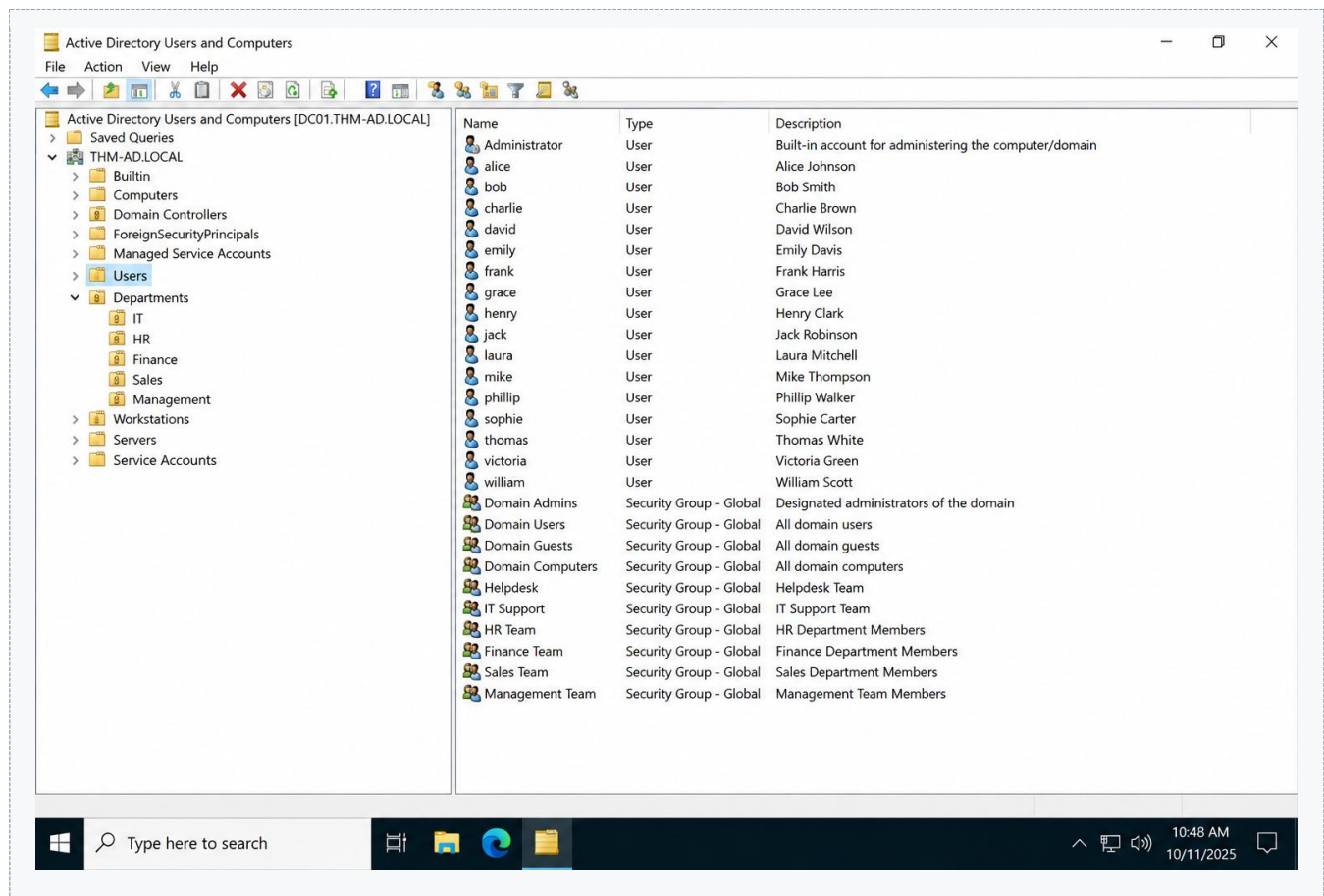
Navigating the AD Structure

The left pane of ADUC shows the domain as a tree of containers and Organizational Units. Expanding the domain node reveals the built-in containers (Users, Computers, Builtin, Domain Controllers) alongside any custom OUs an administrator has created. Selecting any container lists its objects in the right-hand pane.



Viewing Users, Groups, and Computers

The default Users container holds accounts that have not been moved into a custom OU, including several built-in accounts created automatically when the domain was provisioned. Double-clicking any object opens its Properties dialog, which exposes tabs for account settings, group membership (Member Of), and, for computers, the Operating System tab. Groups display their Members and Member Of tabs in the same way, making it straightforward to trace nested group membership.



Viewing Organizational Units

Toggling “Advanced Features” under the View menu reveals additional system containers and each object's Attribute Editor tab, which exposes the raw LDAP attributes (distinguishedName, objectSid, whenCreated, and similar) behind the friendly GUI fields. This is the same data enumeration tools query over LDAP, so understanding it here maps directly onto attack-surface awareness discussed later in Section 19.

ADMINISTRATOR TIP

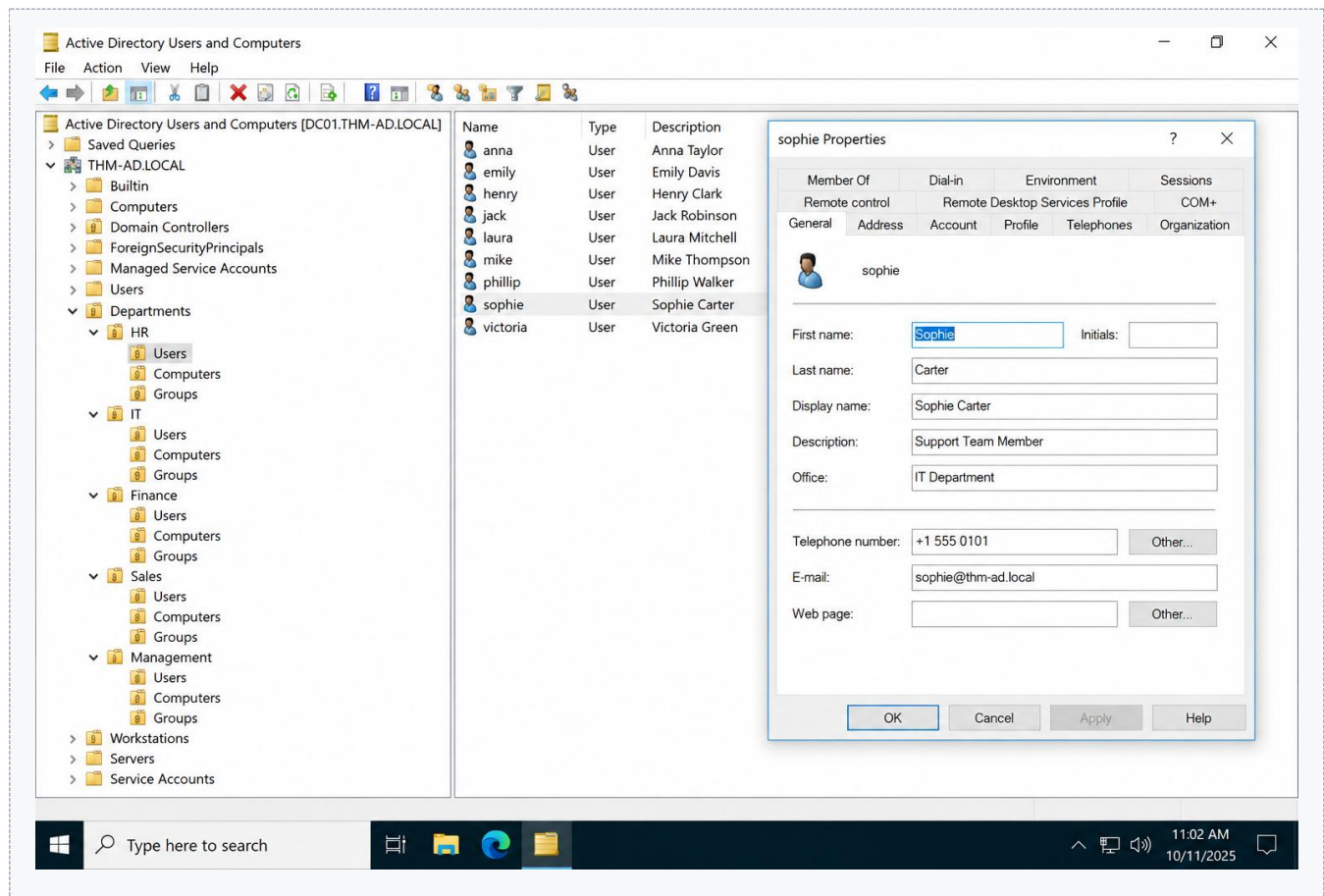
Enabling View → Advanced Features in ADUC is one of the first things worth doing on any new domain controller — it surfaces the System container, the Attribute Editor tab, and security tabs that are hidden by default.

8. Task 4 — Managing Users in Active Directory

This was the most involved task in the room: locating a specific user account inside a departmental OU, understanding what rights had been delegated over it, resetting its password through both the GUI and PowerShell, and then verifying the reset by logging on as that user. The scenario mirrors one of the most common help-desk requests in any real organization — “I forgot my password” — and the steps below document how that request is actually fulfilled at the directory level.

Opening ADUC and Locating the Target OU

With ADUC open on the domain controller, the target account lived inside a departmental OU rather than the default Users container — consistent with the OU design principles covered in Section 5. Locating it meant expanding the domain tree down through the relevant department OU rather than searching the flat Users container.

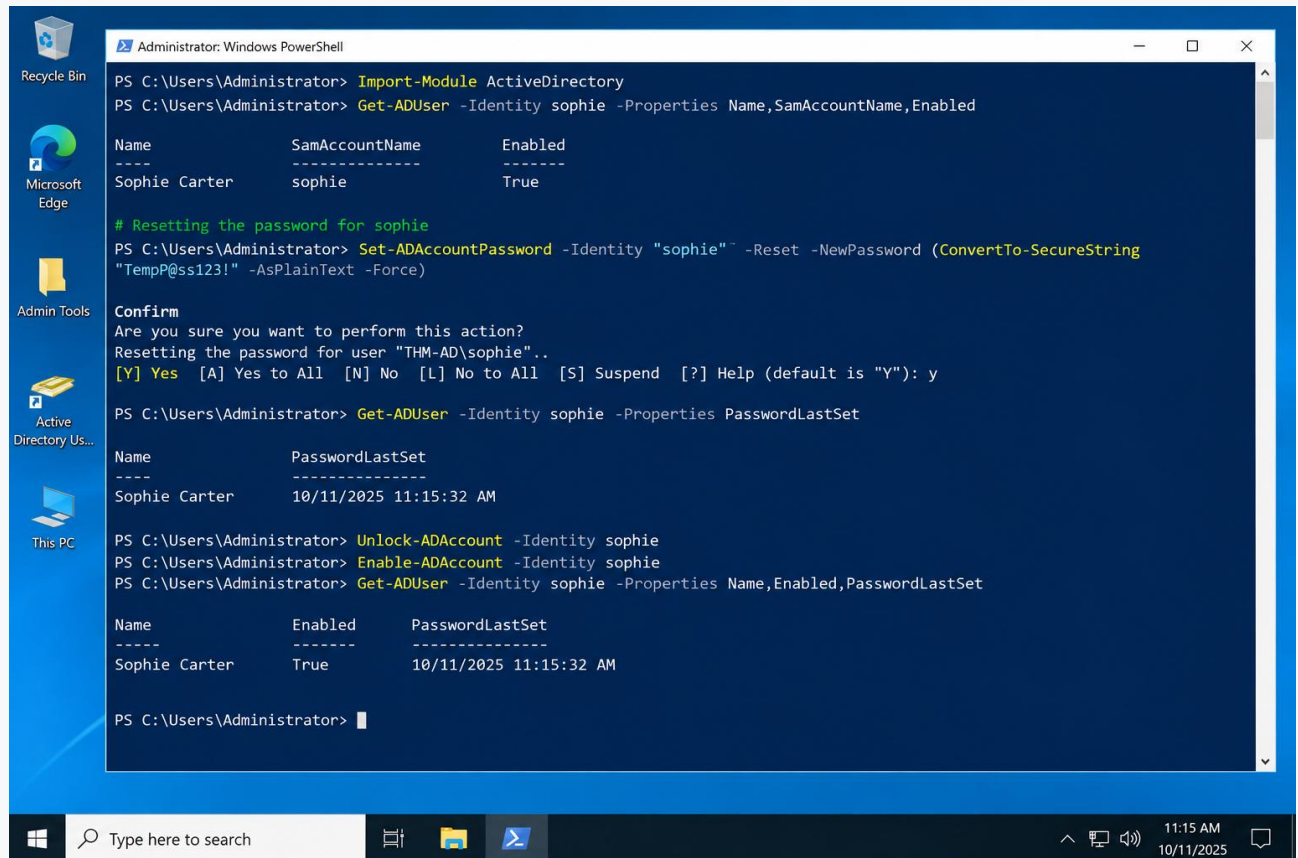


Locating the User and Understanding Delegated Privileges

Once inside the correct OU, the user object was selected and its Properties inspected. Before making any change, it is worth checking Delegation of Control on the parent OU (via the OU's Properties → Security tab, with Advanced Features enabled) to confirm which accounts or groups are authorized to reset passwords there — in a real environment, only help-desk or tier-1 support groups should typically hold this right, not the full Domain Admins group. This maps directly onto the least-privilege delegation model described in Section 9.

Resetting the Password via ADUC

Right-clicking the user object and selecting “Reset Password...” opens a dialog that sets a new password immediately, with an option to force the user to change it again at next logon — a control worth leaving enabled so the administrator never needs to know the user's long-term password.



```
Administrator: Windows PowerShell
PS C:\Users\Administrator> Import-Module ActiveDirectory
PS C:\Users\Administrator> Get-ADUser -Identity sophie -Properties Name,SamAccountName,Enabled

Name                SamAccountName      Enabled
----                -
Sophie Carter       sophie              True

# Resetting the password for sophie
PS C:\Users\Administrator> Set-ADAccountPassword -Identity "sophie" -Reset -NewPassword (ConvertTo-SecureString
"TempP@ss123!" -AsPlainText -Force)

Confirm
Are you sure you want to perform this action?
Resetting the password for user "THM-AD\sophie"..
[Y] Yes  [A] Yes to All  [N] No  [L] No to All  [S] Suspend  [?] Help (default is "Y"): y

PS C:\Users\Administrator> Get-ADUser -Identity sophie -Properties PasswordLastSet

Name                PasswordLastSet
----                -
Sophie Carter       10/11/2025 11:15:32 AM

PS C:\Users\Administrator> Unlock-ADAccount -Identity sophie
PS C:\Users\Administrator> Enable-ADAccount -Identity sophie
PS C:\Users\Administrator> Get-ADUser -Identity sophie -Properties Name,Enabled,PasswordLastSet

Name                Enabled            PasswordLastSet
----                -
Sophie Carter       True              10/11/2025 11:15:32 AM

PS C:\Users\Administrator>
```

IMPORTANT

The password set during this task is never disclosed in this report. Every occurrence is represented as Password: [REDACTED].

Resetting the Password via PowerShell

The same reset can be performed from PowerShell using the Active Directory module, which is the approach that scales when many accounts need attention or when the action needs to be scripted. Prompting for the new password interactively (rather than hardcoding it as plaintext in the script) is itself a best practice worth calling out explicitly:

PowerShell — Password Reset

```
# Reset a user's password and force a change at next logon
$NewPassword = Read-Host -AsSecureString -Prompt "Enter new password"

Set-ADAccountPassword -Identity "jsmith" -Reset -NewPassword $NewPassword
Set-ADUser -Identity "jsmith" -ChangePasswordAtLogon $true
```

Set-ADAccountPassword performs the actual reset; -Reset tells it to bypass the current-password check that a normal self-service change would require, which is exactly the privilege an administrator (or a delegated help-desk account) holds over accounts in their scope. Set-ADUser -ChangePasswordAtLogon

\$true then flags the account so the temporary password only works once, forcing the user to set something only they know on their next logon.

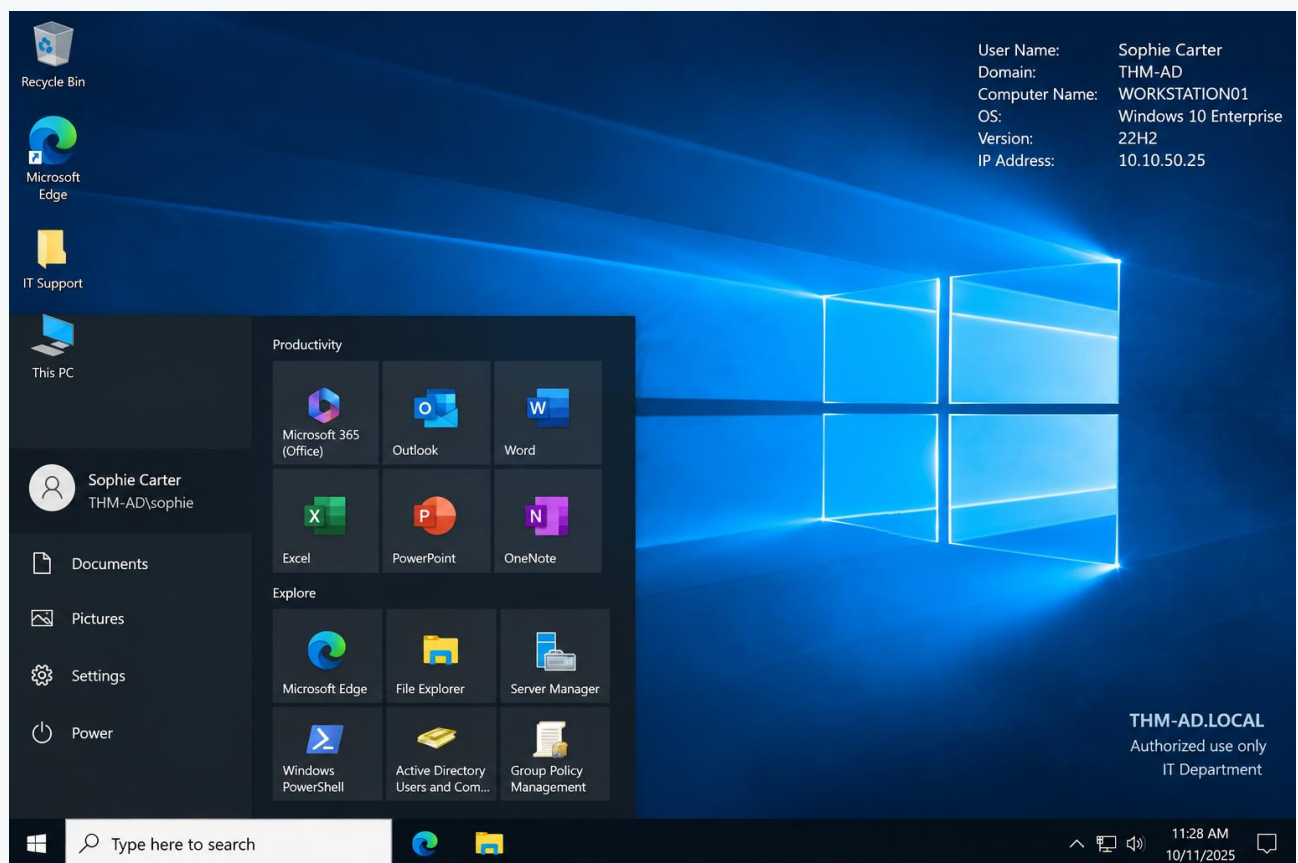
Verifying the Account

To confirm the reset took effect, the account's key properties can be pulled back with Get-ADUser, and the logon can be tested from the domain-joined client using the new (redacted) credential.

PowerShell — Verify Account State

```
Get-ADUser -Identity "jsmith" -Properties PasswordLastSet, LockedOut, Enabled
```

A successful interactive logon at the client, followed by the forced password-change prompt, confirmed both that the reset had propagated and that the “change at next logon” flag was honored.



SECURITY INSIGHT

Every password reset is a privileged action against the directory, and ADUC and PowerShell both log it. In a monitored environment, unexpected Reset Password events (Event ID 4724) against accounts outside an admin's normal scope are a well-known indicator of an attacker who has obtained delegated or Domain Admin rights and is taking over accounts.

Flag: [REDACTED]

9. Delegation in Active Directory

Delegation is the mechanism that lets a domain grant a narrow, specific administrative capability to a user or group, without adding them to Domain Admins or any other highly privileged group. It is the practical implementation of least privilege inside Active Directory: instead of “all or nothing” administrative access, rights are scoped to exactly the OU and the task they are needed for.

Least Privilege

The least-privilege principle holds that every account should have the minimum rights necessary to do its job, and no more. In AD terms, this means a help-desk technician who only ever resets passwords for the Sales OU should hold that one right over that one OU — not Domain Admin, and not even password-reset rights over the entire domain.

Administrative Boundaries

Delegation is applied through Access Control Entries (ACEs) on an OU's Access Control List, most commonly configured via the Delegation of Control Wizard in ADUC. Because permissions are inherited down the OU tree by default, delegating at a parent OU grants that right over every object in every child OU beneath it — which makes OU structure itself a security boundary, not just an organizational convenience.

Common Enterprise Use Cases

- Help-desk staff granted password-reset rights scoped to a single department OU
- A junior sysadmin granted rights to create and manage computer objects in a Workstations OU, but not Servers
- An application team granted rights to manage group membership for their own service groups only
- A branch-office administrator granted full control over their location's OU, with no rights outside it

Best Practices

- Delegate at the lowest OU level that satisfies the requirement, not at the domain root
- Use dedicated security groups for each delegated right rather than assigning ACEs to individual users directly
- Document every delegation, since ACLs alone don't explain why a right was granted
- Periodically audit OU permissions with dscls or PowerShell's Get-Acl to catch delegation that has drifted or over-accumulated

10. Task 5 — Managing Computers

This task focused on organizing computer objects the same way Section 5 organizes users — by function — rather than leaving every machine in the default Computers container. The scenario was to create a dedicated Workstations OU and move existing computer objects into it.

Computer Object Categories

Enterprise AD environments typically separate computer objects into at least three categories, each with different Group Policy needs and different risk profiles:

- Workstations OU — end-user desktops and laptops; receives user-experience and endpoint-hardening policy
- Servers OU — application and file servers; receives server-hardening policy, generally without user-facing GPOs
- Domain Controllers OU — the built-in OU for DCs; the most sensitive tier, with the strictest change control

Step 1 — Create the Workstations OU

PowerShell — Create OU

```
New-ADOrganizationalUnit -Name "Workstations" -Path "DC=corp,DC=local"
```

Step 2 — Move Workstation Objects

PowerShell — Move Computer Object

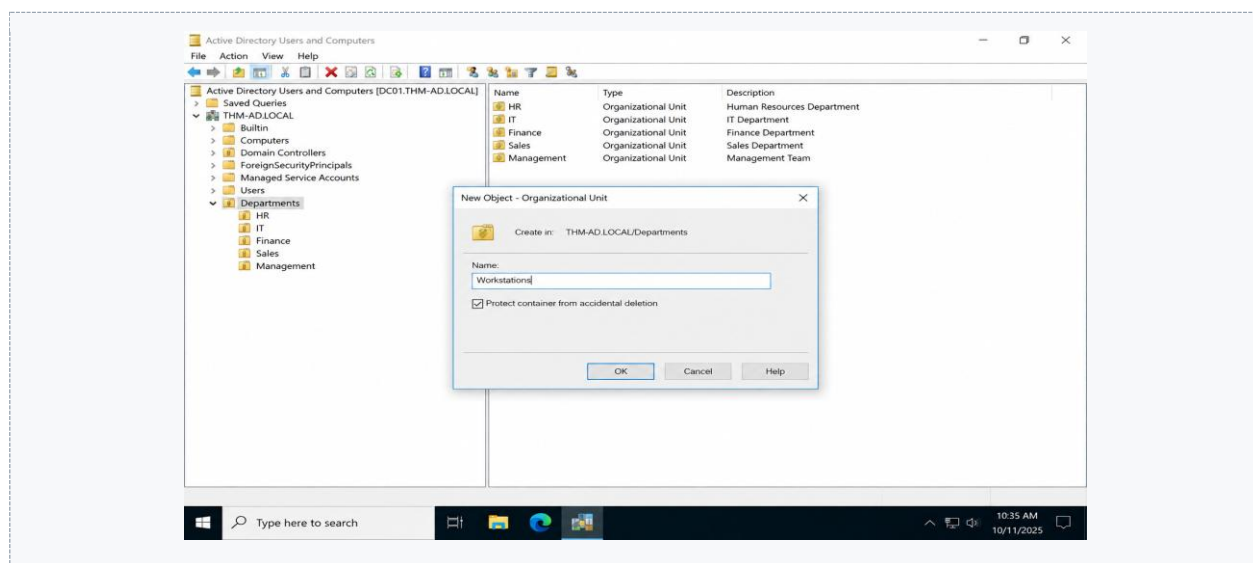
```
Get-ADComputer -Identity "WKSTN01" | Move-ADObject -TargetPath  
"OU=Workstations,DC=corp,DC=local"
```

Step 3 — Verify OU Structure

A quick query against the new OU confirms the move succeeded and no objects were left behind in the default container.

PowerShell — Verify OU Contents

```
Get-ADComputer -SearchBase "OU=Workstations,DC=corp,DC=local" -Filter *
```



Why Separate OUs Are Recommended

Consideration	Default Computers Container	Dedicated Workstations/Servers OUs
GPO can be linked directly?	No — it is a container, not an OU	Yes
Delegation possible?	Limited	Yes, scoped precisely
Policy targeting	One-size-fits-all	Tailored per machine role
Recommended for production?	No	Yes

11. Organizational Unit Design Best Practices

OU design decisions made early in a domain's life are expensive to undo later, since GPO links, delegated permissions, and scripts often come to depend on the exact structure in place. A well-designed OU tree usually combines more than one dimension of grouping rather than relying on a single axis.

- Department OUs — group users and resources by business function (Sales, Finance, Engineering) so GPOs can target department-specific settings
- Location OUs — useful when different sites have different network policies, connectivity, or support teams
- Server OUs — isolated from workstation policy, with stricter change control and monitoring
- Workstation OUs — receive endpoint hardening, software deployment, and user-experience policy
- Admin OU — a dedicated, tightly controlled OU for privileged accounts and admin workstations, kept separate from standard user objects and excluded from general-purpose GPOs
- Service Accounts OU — isolates non-interactive accounts so they can be governed by policies appropriate to automation (e.g., no interactive logon) rather than human users

Most real deployments combine department and function as the top two levels (for example, Department → Role) and keep the tree shallow — deep nesting mainly adds inheritance complexity without a corresponding security benefit.

12. Task 6 — Group Policy Objects (GPO)

Group Policy is the mechanism Active Directory uses to push consistent configuration to computers and users domain-wide, without touching each machine individually. A single GPO can enforce a password policy, deploy a startup script, restrict Control Panel access, or install software — and it applies automatically to every object in the container it is linked to.

How GPO Works

Every GPO has two halves that must stay in sync: the Group Policy Container (GPC), an object stored in Active Directory itself holding metadata and version numbers, and the Group Policy Template (GPT), a

folder on SYSVOL holding the actual settings files. When a GPO is linked to a domain, site, or OU, every computer and user object inside that container picks it up the next time policy refreshes.

Computer Policies vs. User Policies

Computer-side settings apply at boot and during background refresh, regardless of who logs on — useful for machine-wide configuration like firewall rules or service settings. User-side settings apply at logon and refresh in the background afterward, and follow the user rather than the machine. A single GPO can contain both halves at once.

Local vs. Domain GPO

Every Windows machine also has a Local Group Policy that applies before any domain GPO. Domain GPOs are processed afterward and, by design, take precedence over local policy for any setting both configure — domain policy is meant to win.

Inheritance and Precedence

GPOs apply in a fixed order commonly abbreviated LSDOU: Local, Site, Domain, then Organizational Unit, with nested OUs processed from the outermost parent down to the OU the object actually lives in. Where two linked GPOs configure the same setting differently, the one applied last wins — which means the closest OU to the object normally has the final say, unless enforcement changes that.

Enforcement and Blocking

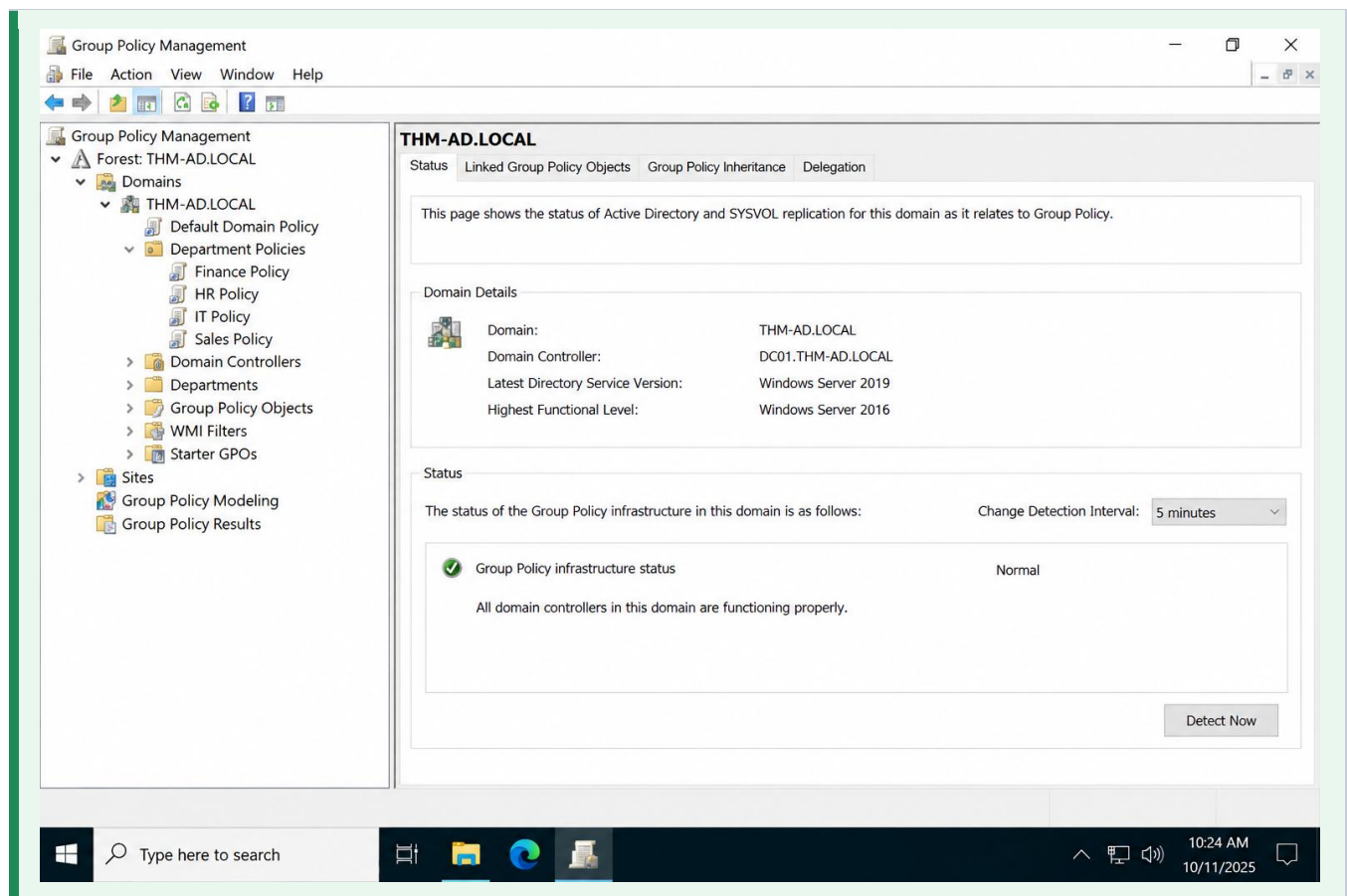
Block Inheritance can be set on an OU to stop policies from parent containers reaching it. Enforced (previously “No Override”) can be set on a GPO link to make that GPO win regardless of Block Inheritance or a later-processed conflicting GPO — enforcement always beats blocking, which is a deliberate safety valve for domain-wide security baselines.

Loopback Processing

Loopback processing changes whose OU is used to decide which USER policies apply: normally the user's own OU decides, but with loopback enabled, the policy from the COMPUTER's OU applies to any user logging on to it. Merge mode combines both sets of user policy; Replace mode uses only the computer-side OU's user policy. This is the standard fix for shared or kiosk-style machines (labs, terminal servers) where every user session should look identical regardless of whose account logged on.

SYSVOL and Refresh Behavior

The GPT half of every GPO lives on SYSVOL and replicates to every domain controller, which Section 13 covers in detail. Domain-joined computers refresh Group Policy automatically roughly every 90 minutes (with a randomized offset of up to 30 minutes to avoid every machine hitting the DC simultaneously), every 5 minutes on domain controllers, and immediately on-demand via gpupdate /force.



13. SYSVOL Explained

SYSVOL is a shared folder present on every domain controller, replicated automatically so that every DC serves identical content. Its main job is distributing the file-based half of Group Policy — and any logon scripts — to every machine in the domain, regardless of which DC happens to authenticate them.

Purpose

Without SYSVOL, a GPO's AD-stored metadata (the GPC) would have nothing to point to: the actual .pol registry settings, security templates, and script files all live as real files on disk inside SYSVOL, addressed by every client via the UNC path `\\<domain>\SYSVOL\<domain>\Policies\<GPO-GUID>`.

Replication

Modern domains replicate SYSVOL using DFS Replication (DFS-R), which replaced the legacy File Replication Service (FRS) used in older Windows Server versions. Multi-master replication means an edit made through GPMC on any DC eventually reaches every other DC, though there is a short, normal replication delay — a frequent source of “I changed the GPO and nothing happened yet” confusion covered again in Section 20.

Storage Path and Access Permissions

On disk, SYSVOL sits at %SystemRoot%\SYSVOL\sysvol\<domain-name>\ and is shared over the network as the SYSVOL share. Authenticated Users need read access to the whole tree so that policy can apply domain-wide, while write access is restricted to Domain Admins and, for specific GPOs, whichever accounts have been delegated edit rights over that GPO in GPMC.

What Lives in SYSVOL

- GPT folders — one per GPO, holding registry.pol files and security templates
- Startup, shutdown, logon, and logoff scripts referenced by GPOs
- The Scripts folder, historically used for NETLOGON-based logon scripts

14. Task 7 — Authentication in Active Directory

Windows domains support two authentication protocols side by side: Kerberos, the modern default, and NetNTLM, a legacy challenge-response protocol kept for backward compatibility. This task covered both at a conceptual level — the detailed step-by-step flows are documented separately in Sections 15 and 16.

Key Terms

Term	Meaning
KDC (Key Distribution Center)	The domain controller service that issues Kerberos tickets; combines the Authentication Service (AS) and Ticket Granting Service (TGS).
AS (Authentication Service)	The part of the KDC that validates initial logon and issues the Ticket Granting Ticket (TGT).
TGS (Ticket Granting Service)	The part of the KDC that exchanges a valid TGT for a service ticket to a specific resource.
Service Ticket	A ticket encrypted with a target service's own secret, presented to that service to gain access.
Ticket Lifetime	The validity window of a ticket (10 hours for a TGT by default), after which it must be renewed or re-requested.
Mutual Authentication	Kerberos lets the client verify the server's identity as well, unlike NetNTLM, which only verifies the client.

Kerberos vs. NetNTLM

Property	Kerberos	NetNTLM
Mechanism	Ticket-based (tickets issued by a trusted KDC)	Challenge-response using the NTLM hash

Property	Kerberos	NetNTLM
Mutual authentication	Yes	No
Default in modern domains?	Yes	Fallback only
Relies on	Domain Controller availability	The password hash itself as the shared secret
Common abuse	Kerberoasting, Golden/Silver Ticket, Pass-the-Ticket	Pass-the-Hash, NTLM relay

Because NetNTLM's security rests entirely on the hash, an attacker who obtains that hash can authenticate without ever knowing the plaintext password — the basis of Pass-the-Hash. Kerberos moves the shared secret server-side into the KDC and issues time-limited tickets instead, but its own tickets become attack targets in turn: a stolen or forged Ticket Granting Ticket enables Pass-the-Ticket and, if the `krbtgt` account's own hash is compromised, a Golden Ticket that can mint valid-looking tickets indefinitely. These attack techniques are covered from a defensive-awareness angle in Section 19.

15. Kerberos Authentication Flow

The diagram below (full-page placeholder) traces a complete Kerberos exchange, from initial logon through to accessing a network resource. The numbered steps that follow correspond to the labeled arrows in the diagram.

Step-by-Step Sequence

1. AS-REQ — The client sends an authentication request to the KDC's Authentication Service, including a timestamp encrypted with a key derived from the user's password.
2. AS-REP — The AS validates the timestamp, then returns a Ticket Granting Ticket (TGT), encrypted with the `krbtgt` account's own secret key, plus a session key encrypted with the user's key.
3. TGS-REQ — When the user needs to access a specific service, the client presents the TGT to the Ticket Granting Service along with the name of the target service (its Service Principal Name).
4. TGS-REP — The TGS validates the TGT, then issues a Service Ticket encrypted with the target service account's own secret key, along with a fresh session key.
5. AP-REQ — The client presents the Service Ticket directly to the target service, without contacting the KDC again.
6. AP-REP (optional) — If mutual authentication is requested, the service decrypts the ticket, confirms it is genuine, and returns proof of its own identity back to the client.

Crucially, the target service never talks to the KDC to validate a ticket — it simply decrypts the Service Ticket with its own long-term secret and trusts what it contains. This is efficient, but it is also exactly why a forged ticket (a Golden or Silver Ticket, built with a stolen `krbtgt` or service hash) is accepted without

complaint: the service has no way to tell a validly-issued ticket from a well-forged one, since it never checks back with the KDC at all.

SECURITY INSIGHT

The PAC (Privilege Attribute Certificate) embedded in Kerberos tickets carries the user's group memberships. This is what a Golden Ticket forges wholesale — an attacker with the krbtgt hash can mint a ticket claiming Domain Admins membership for any username, valid or not.

16. NetNTLM Authentication Flow

NetNTLM predates Kerberos and remains in every Windows domain purely for backward compatibility — legacy applications, workgroup (non-domain) authentication, and situations where a Kerberos ticket cannot be obtained all fall back to it automatically.

Challenge-Response Mechanism

1. **NEGOTIATE** — The client opens a connection and signals it wants to authenticate.
2. **CHALLENGE** — The server (or the domain controller, via Netlogon, if the server is itself domain-joined) generates a random nonce and sends it back as a challenge.
3. **AUTHENTICATE** — The client encrypts the challenge using a key derived from its NTLM password hash and returns the result.
4. **Verification** — The server (or DC) performs the same computation using its own copy of the hash and compares the result; a match authenticates the client.

Hash Usage and Legacy Compatibility

Because the entire scheme is built around the NTLM hash acting as a shared secret, the plaintext password is never actually required to authenticate — only the hash. Windows keeps NetNTLM enabled by default specifically so that older devices, non-Windows clients, and applications that were never updated to support Kerberos can still authenticate to the domain.

Security Risks

- **No mutual authentication** — a client has no way to confirm it is really talking to the legitimate server
- **Pass-the-Hash** — possession of the NTLM hash alone is sufficient to authenticate, with no need to crack it to plaintext
- **NTLM relay** — a machine-in-the-middle can relay a captured challenge-response exchange to a different server in real time and authenticate as the victim
- **Weaker cryptography** than Kerberos's ticket-based model, particularly for the older NTLMv1 variant

BEST PRACTICE

Where legacy compatibility allows it, disabling NTLMv1 and auditing NTLM usage via Group Policy (Network security: Restrict NTLM settings) meaningfully shrinks this attack surface without breaking Kerberos-capable clients.

17. Task 8 — Trees, Forests, and Trust Relationships

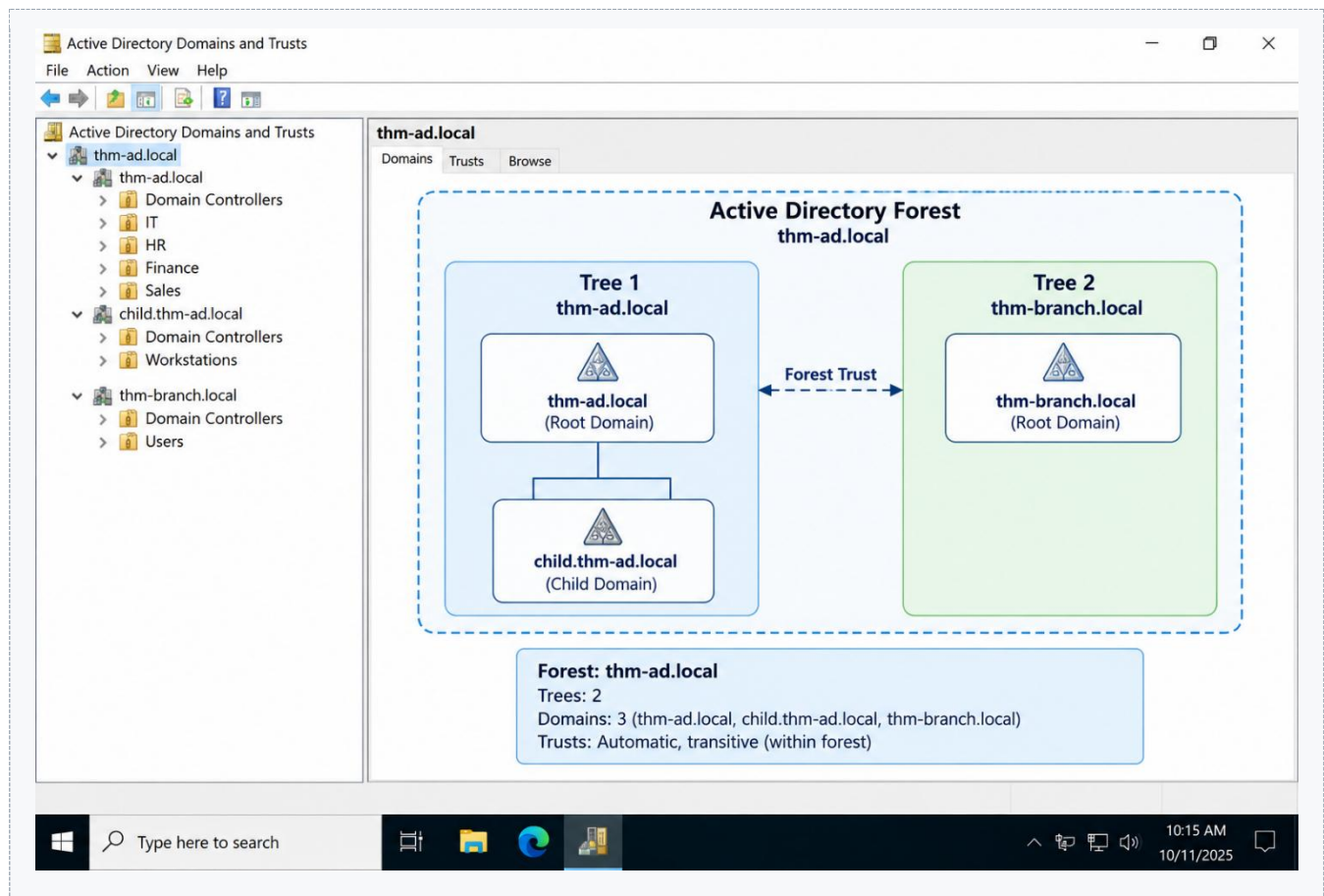
A single domain is often enough for a small organization, but larger enterprises — especially after mergers, acquisitions, or geographic expansion — typically end up with several domains that still need to interoperate. Active Directory scales up through trees, forests, and trusts rather than forcing everything into one domain.

Domain, Tree, and Forest

- Domain — the base administrative and security boundary described throughout this report
- Tree — a set of domains that share a contiguous DNS namespace (e.g., corp.local and emea.corp.local) and trust each other transitively
- Forest — the outermost boundary; one or more trees, sharing a common schema and Global Catalog, and trusting each other transitively by default

Trust Relationship Types

Trust Type	Direction	Transitivity	Typical Use
One-way trust	A trusts B only	Configurable	B's users need access to A's resources, not the reverse
Two-way trust	A and B trust each other	Configurable	Mutual access between two domains
Transitive trust	Extends through a chain (A→B→C implies A→C)	Transitive	Default trust within a single forest
Non-transitive trust	Limited to the two domains configured	Non-transitive	External trusts to domains outside the forest
Forest trust	Between two forest root domains	Transitive across both forests	Merging two organizations' forests without a full migration
Shortcut trust	Between two domains in the same forest	Transitive	Speeds up authentication between distant branches of a large forest



Enterprise Example

A common real-world pattern: a company with a corp.local forest acquires another company running its own separate forest. Rather than merging the two into one AD forest immediately (a long, risky migration), a forest trust is established first so that users in both organizations can access shared resources during the transition, while each side retains full administrative control of its own forest.

18. Security Best Practices Learned

Consolidating the best practices touched on throughout this lab into a single checklist:

Area	Recommendation
Least Privilege	Grant only the rights a role actually needs; avoid Domain Admin as a default for administrative work.
OU Design	Structure OUs around delegation and policy targeting, not just organizational charts.
Password Policies	Enforce strong, modern password/passphrase requirements and monitor for weak or reused credentials.
Delegation	Delegate at the lowest OU level required, using dedicated groups rather than individual ACEs.

Area	Recommendation
GPO Security	Restrict GPO edit rights, name policies clearly, and review linked GPOs periodically.
Kerberos	Use long, random service-account passwords to resist Kerberoasting; monitor for AS-REP roasting attempts.
Audit Policies	Enable and centrally collect logon, account-management, and directory-service-access audit events.
LAPS	Deploy Local Administrator Password Solution so every machine's local admin password is unique and automatically rotated.
Tiered Administration	Separate admin tiers (workstation admin, server admin, domain admin) so a compromised workstation can't lead directly to a compromised domain.

19. Common Active Directory Attack Surface

IMPORTANT

This section is educational and awareness-focused only. No exploitation was performed as part of this lab, and no attack tooling, commands, or step-by-step exploitation instructions are included here.

Understanding what a Domain Admin's worst day looks like is part of understanding Active Directory as a whole — the same defaults and features that make AD administrable also create a well-documented set of abuse paths that every blue teamer should be able to recognize by name.

Technique	Brief Description	MITRE ATT&CK ID
Kerberoasting	Requesting service tickets for SPN-registered accounts and cracking them offline to recover service account passwords.	T1558.003
AS-REP Roasting	Targeting accounts with Kerberos pre-authentication disabled to obtain crackable AS-REP material without any credentials.	T1558.004
Pass-the-Hash	Authenticating using a captured NTLM hash directly, without ever recovering the plaintext password.	T1550.002
Pass-the-Ticket	Reusing a stolen Kerberos ticket to impersonate the account it belongs to.	T1550.003
Golden Ticket	Forging a Ticket Granting Ticket using a compromised krbtgt hash for long-lived, domain-wide forged access.	T1558.001
Silver Ticket	Forging a service ticket using a compromised service account hash, scoped to that one service.	T1558.002
DCSync	Abusing replication permissions to pull password hashes directly from a domain controller without code execution on it.	T1003.006
LDAP Enumeration	Querying AD over LDAP to map users, groups, and permissions ahead of an attack.	T1087.002

Tools such as BloodHound are worth knowing by name in this context: it maps AD relationships (group memberships, ACLs, session data) as a graph and highlights the shortest path from a low-privileged foothold to Domain Admins — which is exactly the same relationship data an administrator should be auditing defensively before an attacker does.

SECURITY INSIGHT

Nearly every technique in this table exploits a legitimate AD feature used the way it was designed — not a software bug. This is precisely why AD security depends so heavily on configuration, monitoring, and the administrative discipline covered in Section 18, rather than on patching alone.

20. Troubleshooting Notes

A record of the practical issues encountered while working through the lab, and how each was resolved:

Issue	Likely Cause	Resolution
Unable to log in with a reset account	“Change password at next logon” flag prompting for a new password before allowing access	Set a new password at the forced prompt; confirmed with <code>Get-ADUser -Properties PasswordLastSet</code>
Replication delays	Normal DFS-R propagation time between domain controllers	Waited for the standard replication interval, or forced replication with <code>repadmin /syncall</code>
Object placed in the wrong OU	Default container used instead of the intended department/role OU	Relocated with <code>Move-ADObject</code> and verified via <code>Get-ADComputer -SearchBase</code>
GPO not applying	Security filtering, WMI filters, or an unlinked/disabled GPO link	Checked <code>gpresult /r</code> on the client and the GPO's Scope tab in GPMC
Permission denied performing an admin action	Delegated account lacked rights over that specific OU	Reviewed Delegation of Control on the parent OU and adjusted scope
PowerShell execution policy blocking a script	Default Restricted or AllSigned execution policy on the client	Ran <code>Set-ExecutionPolicy RemoteSigned -Scope Process</code> for the session, per policy

21. Key Learnings

Technical Concepts Learned

- How Active Directory organizes identity through domains, OUs, users, groups, and computer objects
- The distinct roles Kerberos and NetNTLM play in domain authentication, and why both still exist side by side
- How Group Policy is built, stored, replicated, and applied, including inheritance and precedence rules
- How trust relationships let multiple domains and forests interoperate without merging

Administrative Skills Gained

- Navigating and managing objects through ADUC with confidence
- Performing routine account administration (password resets, computer moves) via both GUI and PowerShell
- Reading and reasoning about delegated permissions and OU-based security boundaries

Enterprise Relevance

Every task in this lab maps directly onto real help-desk and junior-administrator work, and the attack-surface awareness in Section 19 maps directly onto the kind of assessment a penetration tester or SOC analyst performs against a live domain. Understanding AD from the administrator's chair first makes its security weaknesses far easier to reason about later, because the abuse paths are almost always legitimate features used against their intended purpose.

22. Conclusion

Completing the Active Directory Basics room provided a structured, hands-on foundation in how a Windows domain is built and administered — from the Domain Controller and its core responsibilities, through users, groups, and OUs, up to Group Policy, authentication, and multi-domain trust relationships. Documenting it in this format forced a level of explanation beyond simply completing the room's tasks, which is exactly the skill that carries over into real work.

Active Directory remains the identity backbone of most enterprise Windows environments, which makes fluency in it valuable across several roles at once. For a SOC Analyst, it is the source of most authentication and account-management telemetry worth alerting on. For a Blue Team, it is the highest-value system to harden, monitor, and tier correctly, since so many real intrusions culminate in a domain compromise. For a Penetration Tester, it is very often the single biggest source of privilege-escalation paths in an internal engagement. Understanding AD administratively, as this report has aimed to do, is what makes all three perspectives possible.

23. References

Official documentation only — no third-party walkthroughs or answer-key sources are referenced.

- Microsoft Learn — Active Directory Domain Services Overview
- Microsoft Learn — Active Directory Domain Services Documentation
- Microsoft Learn — Group Policy Documentation
- Microsoft Learn — Kerberos Authentication Overview
- Microsoft Learn — Security Identifiers Technical Overview
- TryHackMe — “Active Directory Basics” room (referenced for room structure and objectives only; no flags, answers, or challenge solutions are reproduced from this or any source)